AWS Security and Identity

AWS foundations, volume 1 · Version 2026.1

> Sample foundation document written for testing a domain-expert RAG. AWS services, limits and model availability change often; confirm details in the official AWS documentation.

1. The shared responsibility model

AWS is responsible for security **of** the cloud: data centres, hardware, the hypervisor and the managed parts of services. The customer is responsible for security **in** the cloud: identities and permissions, network configuration, operating systems on EC2, application code, and data classification and encryption. The more managed the service, the more AWS takes on; with Lambda you do not patch servers, but you still own the function's permissions and code.

2. IAM building blocks

Concept	What it is	Good practice
Root user	The account owner identity with unrestricted access	Enable MFA, remove access keys, use only for the few tasks that need it
IAM user	A long-lived identity with credentials	Avoid for people; use federation through IAM Identity Center
IAM role	An identity assumed temporarily by a service, user or workload	Default choice for workloads (EC2 instance profiles, Lambda execution roles, EKS pod identities)
Identity-based policy	Permissions attached to a user, group or role	Grant least privilege; scope resources and conditions
Resource-based policy	Permissions attached to a resource, such as an S3 bucket policy or KMS key policy	Use for cross-account access; always name principals explicitly
Service control policy (SCP)	An AWS Organizations guardrail on the maximum permissions in accounts	Deny disabling CloudTrail, leaving the organisation, or using unapproved regions

Permissions boundary	A cap on what an identity's policies can grant	Let teams create roles safely without escalating privilege

3. How IAM evaluates a request

1. Everything starts as an implicit deny.
2. An explicit **Deny** in any applicable policy always wins.
3. SCPs, permissions boundaries and session policies must all allow the action.
4. An identity-based or resource-based policy must explicitly **Allow** it.

Conditions such as `aws:SourceIp`, `aws:PrincipalOrgID`, `aws:SecureTransport` and resource tags make policies much tighter. Avoid wildcards like `"Action": "*"` and `"Resource": "*"`; IAM Access Analyzer can generate least-privilege policies from CloudTrail activity and find resources shared outside the account.

```
{"Effect": "Allow",
 "Action": ["s3:GetObject"],
 "Resource": "arn:aws:s3:::invoices-prod/*",
 "Condition": {"Bool": {"aws:SecureTransport": "true"}}}
```

4. Credentials

Prefer temporary credentials from roles and IAM Identity Center over long-lived access keys. If access keys are unavoidable, rotate them, never commit them to code, and alert on their use from unexpected locations. Store application secrets in AWS Secrets Manager, which supports automatic rotation for databases, or in Systems Manager Parameter Store for simpler configuration values.

5. Encryption with KMS

AWS Key Management Service (KMS) manages encryption keys. Most services encrypt data with a data key that KMS generates and protects with a KMS key (envelope encryption). Customer managed keys let you control the key policy, rotation and who can decrypt; AWS managed keys are simpler but less controllable. Key policies are resource-based policies, so a principal needs permission both in IAM and in the key policy. Automatic key rotation can be enabled for customer managed symmetric keys.

6. Logging and detection

Service	Purpose
AWS CloudTrail	Records API calls across the account; create an organisation trail to a locked-down S3 bucket
Amazon CloudWatch	Metrics, logs, alarms and dashboards
Amazon GuardDuty	Threat detection from CloudTrail, VPC Flow Logs, DNS logs and more
AWS Security Hub	Aggregates findings and checks against security standards
AWS Config	Records resource configuration and evaluates compliance rules
IAM Access Analyzer	Finds external access and unused permissions

7. Multi-account strategy

Use AWS Organizations with separate accounts for production, non-production, security tooling and log archive. Accounts are the strongest isolation boundary in AWS. AWS Control Tower sets up a landing zone with guardrails, centralised logging and account vending. Apply SCPs at organisational units rather than individual accounts.